

Memory injection:

Finding Malware:

Malware runs in memory:

- Memory forensics can find the malicious code.

Memory contains running processes:

- DLLs (Dynamic Link Libraries)
- Threads
- Buffers
- Memory management functions
- And much more

Malware is hidden somewhere:

- Malware runs its own process
- Malware injects itself into a legitimate process

Add code into the memory of an existing process:

- Hide malware inside of the process

Get Access to the data in that process:

- And the same rights and permissions
- Perform a privilege escalation

DLL injection:

Dynamic link library:

- A windows library containing code and data
- Many applications can use this library

Attackers inject a path to a malicious DLL:

- Runs as part of the target process

One of the most popular memory injection methods:

- Relatively easy to implement

Buffer OverFlows

Overwriting a buffer of memory:

- Spills over into over memory areas

Developers need to perform bounds checking:

- The Attackers spend a lot of time looking for openings

Not a simple exploit;

- Takes time to avoid crashing
- Takes time to make it do what you want

A really useful buffer overflow is repeatable:

- Which means that a system can be compromised

Variable Name	A								B	
Value	[null string]								1979	
Hex Value	00	00	00	00	00	00	00	00	07	BB

Variable Name	A								B	
Value	'e'	'x'	'c'	'e'	's'	's'	'i'	'v'	25856	
Hex Value	65	78	63	65	73	73	69	76	65	00

In the first table we see that there are 2 variables A and B. A is empty and B has a value of 1979 associated to it with a hex value of 07 and BB. In order to to gain administration rights the value for B must be anything over 24000. So what attackers do is perform a buffer overflow by seeing a vulnerability in B by seeing there 8 empty bits in A and an empty bit in B. So in the second table the attacker decides to put the characters that are in word “excessive” into A and the last letter ‘e’ is now in variable B and the hex value of ‘e’ is 65 which is an overflow. Since this overflow occurred, the new value of B is greater than 24000 which now provides the user with admin access.

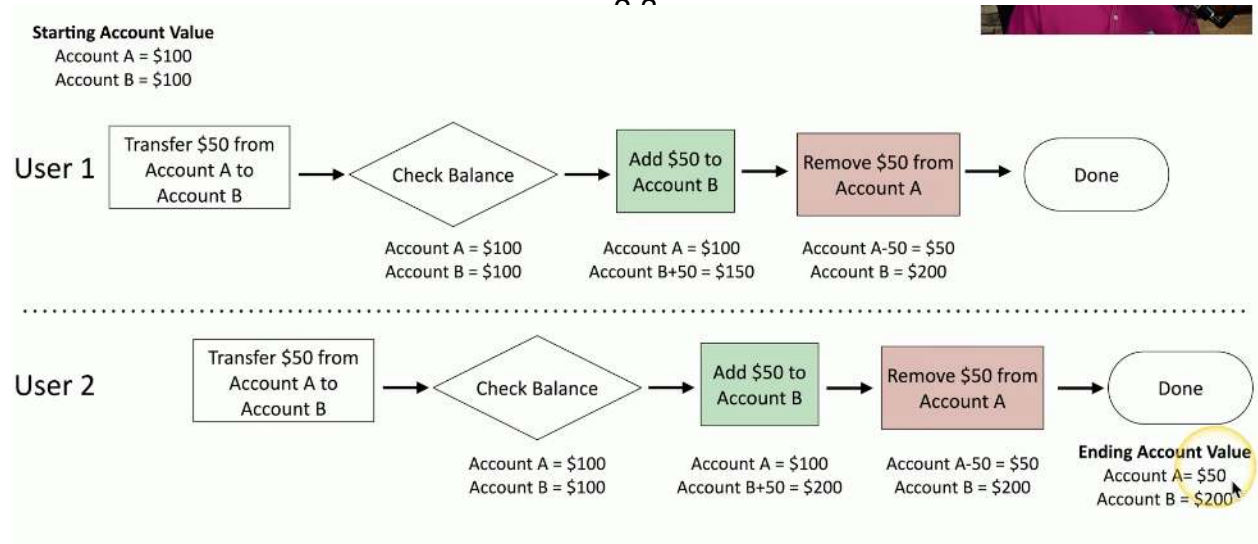
Race Conditions

A programing conundrum:

- Sometimes, things happen at the same time
- This can be bad if you’re not prepared

Time-of-check to time-of-use attack (TOCTOU):

- Check the system
- When do you use the results of your last check?
- Something might happen between the check and the use



Account 1 should have zero dollars by the end of the money transfers but instead has 50 dollars because of there was 2 removals of cash coming from 2 different users at the same time. Therefore the balance of the account wasn't checked between the 2 withdrawals causing an error in our final balance of account 1.

January 2004 - Mars rover 'Spirit':

- Reboot when a problem is identified
- Problem is with file system, so reboot because of the file system problem
- Reboot loop was the result

Pwn2Own Vancouver 2023 - Tesla model 3:

- TOCTOU attack against the Tesla infotainment using bluetooth
- Elevated privileges to root
- Earned \$100,000 US prize and they keep the Tesla

Malicious Updates

Software updates

Always keep your operating system and applications updated:

- Updates often include bug fixes and security patches

This process has its own security concerns:

- Not every update is equally secure

Follow best practices:

- Always have a known good backup
- Install from trusted sources
- Did I mention the backup?

Downloading and Updating:

Install updates from a downloaded file:

- Always consider your actions
- Every installation could potentially be malicious

Confirm the source:

- A random pop-up during web browsing may not be legit

Visit the developers site directly:

- Don't trust a random update button or random downloaded file

Many Operating systems will only allow signed apps:

- Don't disable your security controls

Automatic updates:

The app updates itself:

- Often includes security checks / digital signatures

Relatively trustworthy:

- Comes directly from the developer

SolarWinds Orion supply chain attack:

- Reported December 2020
- Attackers gained access to the SolarWinds development system
- Added their own malicious code to the updates
- Gained access to hundreds of government agencies and companies

Operating System vulnerabilities

Operating systems:

A foundational computing platform:

- Everyone has a operating system
- This makes the OS a very big target

Remarkably complex:

- Millions of lines of code
- More code means more opportunities for a security issue.

The Vulnerabilities are already in there:

- We just haven't found them yet

A month of OS updates:

A normal month of windows updates:

- Patch Tuesday - 2nd Tuesday of each month
- Other companies have similar schedules

May 9th, 2023 - Nearly 50 security patches:

- 8 Elevation of Privilege vulnerabilities
- 4 Security Feature Bypass Vulnerabilities
- 12 Remote Code execution vulnerabilities
- 8 Information disclosure Vulnerabilities
- 5 Denial of Service Vulnerabilities
- 1 spoofing Vulnerability

Best Practices for OS vulnerabilities:

Always Update:

- Monthly or on-demand updates
- Its a race between you and the attackers

May require testing before deployment:

- A patch might break something else

May require a reboot:

- Save all data

Have a fallback plan:

- Where's that backup?

SQL Injection

Code injection:

- Adding your own information into the data stream

Enabled because of bad programming:

- The application should properly handle input and output

So many different data types:

- HTML, SQL, XML, LDAP, etc.

SQL injection - Structured Query Language:

- The most common relational database management system

SQL injection (SQLi):

- Put your own SQL requests into an existing application
- Your application shouldn't allow this

Can often be executed in a web browser:

- Injected in a form or field

■ An example of website code:

```
"SELECT * FROM users WHERE name = '" + userName + "'";
```

■ How this looks to the SQL database:

```
"SELECT * FROM users WHERE name = 'Professor'";
```

■ Add more information to the query:

```
"SELECT * FROM users WHERE name = 'Professor' OR '1' = '1'";
```

Injected code

This could be very bad:

- View all database information, delete database information, add users, denial of service, etc.

■ Employee: Smith

Authentication TAN: 3SL99A

Employee Name:

Authentication TAN:

That is only one account. You want them all! Try again.

USERID	FIRST_NAME	LAST_NAME	DEPARTMENT	SALARY	AUTH_TAN
37648	John	Smith	Marketing	64350	3SL99A

Without injection

■ Employee: Smith Authentication TAN: 3SL99A

Employee Name:

Authentication TAN:

You have succeeded! You successfully compromised the confidentiality of data by viewing internal information that you should not have access to. Well done!

USERID	FIRST_NAME	LAST_NAME	DEPARTMENT	SALARY	AUTH_TAN
32147	Paulina	Travers	Accounting	46000	P45JSI
34477	Abraham	Holman	Development	50000	UU2ALK
37648	John	Smith	Marketing	64350	3SL99A
89762	Tobi	Barnett	Development	77000	TA9LL1
96134	Bob	Franco	Marketing	83700	LO9S2V

With Injection

Cross-site Scripting

XSS

- Cascading Style Sheets (CSS) are something else entirely

Originally called cross-site because of browser security flaws:

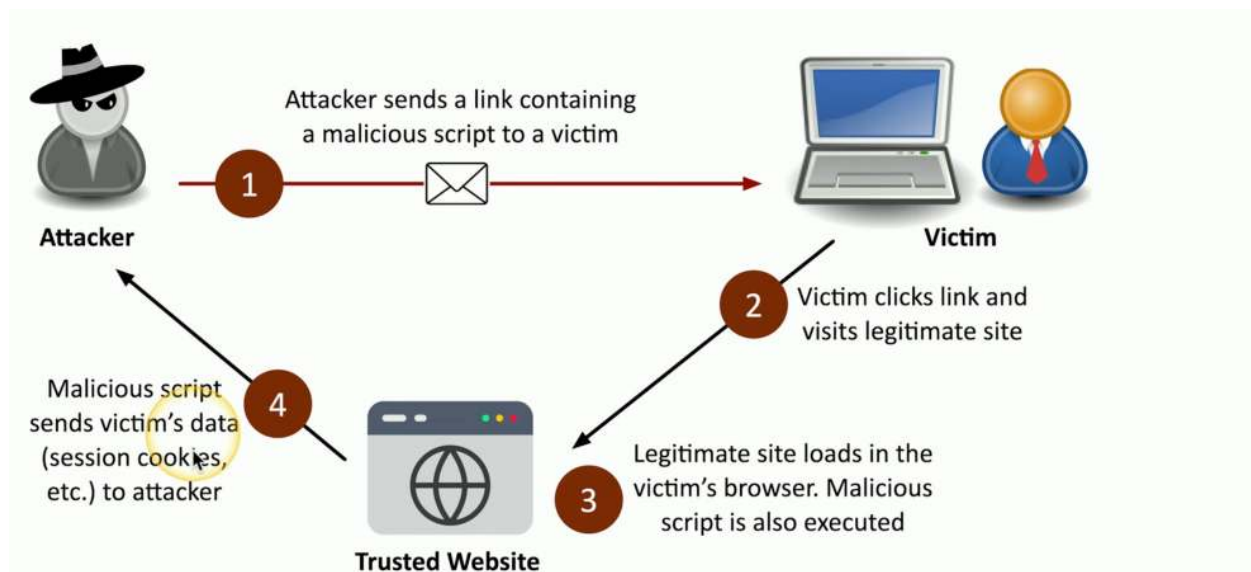
- Information from one site to another could be shared with another

One of the most common web app vulnerabilities:

- Takes advantage of the trust of a user has for a site
- Complex and varied

XSS commonly uses Javascript:

- Do you allow scripts? Me too.



XSS how it works conceptually

Non-persistent (reflected) XSS attack:

Web site allows scripts to run in user input

- Search box is a common source

Attacker emails a link that takes advantage of this vulnerability:

- Runs a script that sends creds / session IDs / Cookies to the attacker

Script embedded in URL executes in the victim's browser:

- As if it came from the server

Attacker uses creds / session ids / cookies to steal the victim's information without their knowledge:

- Very sneaky

Persistent (stored) XSS attack:

Attacker posts a message to a social network:

- Includes the malicious payload

It's now persistent:

- Everyone gets the payload

No specific target:

- All viewers on the page

2.3

For social networking, this can spread quickly:

- Everyone who views the message can have it posted to their page
- Where someone else can view it and propagate it further

Hacking a subaru

June 2017, Aaron Guzman:

- Security researcher

When Authenticating with Subaru, users get a token:

- This token never expires (bad)

A valid token allowed any service request:

- Even adding your email address to someone else's account
- Now you have full access to someone else's car

Web front-end included an XSS vulnerability:

- A user clicks a malicious link, and you have their token

Protecting against XSS:

Be careful when clicking untrusted links:

- Never blindly click your email inbox ever

Consider disabling JavaScript:

- Or control with an extension
- This offers limited protection

Keep your browser and apps updated:

- Avoid the nasty browser vulnerabilities

Validate input:

- Don't allow users to add their own scripts to an input field

Hardware Vulnerabilities:

We are surrounded by hardware devices:

- Many don't have an accessible operating system

These devices are potential security issues:

- A perfect entry point for an attack

Everything is connecting to the network:

- Light bulbs, garage doors, refrigerators, door locks
- IoT is everywhere

The security landscape has grown:

- Time to change your approach

Firmware

The software inside the hardware:

- The Operating system of the hardware device

Vendors are the only ones who can fix their hardware:

- Assuming they know about the problem
- And care about fixing it

Trane Comfortlink II thermostats:

- Control the temperature from your phone
- Trane notified of three vulnerabilities in April 2014
- Two patched in April 2015, one in January of 2016

End-of-Life:

End of Life (EOL):

- Manufacturer stops selling a product
- May continue supporting the product
- Important for security patches and updates

End of Service life (EOSL):

- Manufacturer stops selling a product
- Support is no longer available for the product
- No ongoing security patches or updates
- May have a premium cost support option

Technology EOSL is a significant concern:

- Security patches are part of normal operation

Legacy Platforms

Some devices remain installed for a long time:

- Perhaps too long

Legacy devices:

- old OS, apps, middleware

May be running end-of-life software:

- The risk needs to be compared to the return

May require additional security protections:

- additional firewall rules
- IPS signatures for older operating systems

Virtualization security:

Quite different than non-virtual machines:

- can appear anywhere

Quantity of resources vary between VMs:

- CPU, Memory, storage

Many similarities to physical machines:

- Complexity adds opportunity for the attackers

Virtualization vulnerabilities:

- Local privilege escalations
- command injection
- Information disclosure

VM escape protection:

The virtual machine is self contained:

- There's no way out
- Or is there

Virtual machine escape:

- Break of the VM and interact with the host operating system or hardware

Once you escape the VM, you have great control:

- Control the host and control other guest VMS

This would be a huge exploit:

- Full control of the virtual world

March 2017 - Pwn2POwn competition:

- Hacking contest
- You pwn it, you own it - along with cash

JavaScript engine big in Microsoft edge:

- Code execution in the edge sandbox

Windows 10 kernel bug:

- compromise the guest OS

Hardware simulation bug in VMware:

- Escape the host

Patches were released soon afterwards

Resource reuse:

The hypervisor manages the relationship between physical and virtual resources:

- Available RAM, Storage space, CPU availability, etc.

These resources can be reused between VMs;

- Hypervisor host with 4GB of RAM
- Supports 3 VMs with 2GB of RAM each
- RAM is allocated and shared between VMs

Data can be inadvertently be shared between VMs:

- Time to update the memory management features
- Security patches can mitigate that risk

Cloud Specific Vulnerabilities

Security in the cloud:

Cloud adoption has been nearly universal:

- Its difficult to find any company not using cloud

We've put sensitive data in the cloud:

- The attackers would like this data

Were not putting in the right protections:

- 76% of organizations aren't using MFA for management console users

Simple best-practices aren't being used:

- 63% of code in production is unpatched
- Vulnerabilities rated high or critical (CVSS ≥ 7.0)

Attack the service:

Denial of service (DoS):

- A fundamental attack type

Authentication bypass:

- Take advantage of weak or faulty authentication

Directory traversal:

- Faulty configurations put data at risk

Remote code execution:

- Take advantage of unpatched systems

Attack the Application

Web application attacks have increased:

- Log4j and Spring Cloud Function
- Easy to exploit, rewards are extensive

Cross-site scripting (XSS):

- Take advantage of poor input validation

Out of bounds write:

- Write to unauthorized memory areas
- Data Corruption, crashing, or code execution

SQL injection:

- Get direct access to database.

Supply chain risk

The chain contains many moving parts:

- Raw materials, suppliers, manufacturers, distributors, customers, consumers

Attackers can infect any step along the way:

- infect different parts of the chain without suspicion
- People trust their suppliers

One exploit can infect the entire chain:

- There's a lot at stake

Service providers

You can control your own security posture:

- you can't always control your service provider

Service providers often have access to internal services:

- An opportunity for the attacker

Many different types of providers:

- Network, utilities, office cleaning, payroll/accounting, cloud services, system administration, etc.

Consider ongoing security audits of all providers:

- Should be included with the contract

Target service provider attack:

Target Corp. breach - November 2013:

- 40 million credit cards stolen

Heating and AC firm in Pennsylvania was infecting:

- Malware delivered in an email
- VPN credentials for HVAC techs was stolen

HVAC vendor was the supplier:

- Attackers used a wide-open Target network to infect every cash register at 1800 stores

Do these technicians look like an IT security issue?

Hardware providers:

Can you trust your new server/router/switch/firewall/software?

- supply chain cyber security

Use a small supplier base:

- Tighter control of vendors

Strict controls over policies and procedures:

- Ensure proper security is in place

Security should be part of the overall design:

- There a limit to trust

Cisco or not Cisco?

All network traffic flows through switches and routers:

- A perfect visibility and pivot point

July 2022 - DHS arrests reseller CEO:

- Sold more than 1 billion dollars of counterfeit Cisco products
- Created over 30 different companies
- Had been selling these since 2013

Knock-offs made In china:

- Sold as authentic Cisco products
- Until they started breaking and catching fire

Software providers:

Trust is a foundation of security:

- Every software installation questions our trust

Initial installation:

- Digital signature should be confirmed during installation

Updates and patches:

- Some software updates are automatic
- How secure are the updates?

Open Source is not immune:

- Compromising the source code itself

SolarWinds supply chain attack

SolarWinds Orion:

- Used by 18000 customers
- Including fortune 500 and US federal government

Software updates compromised in March and June of 2020:

- Upgrades to existing installations
- Not detected until December of 2020

Additional breaches took advantage of the exploit:

- Microsoft, CISCO, intel, Deloitte
- Pentagon, Homeland security, State department, Department of Energy, National Nuclear Security Administration, Treasury

Misconfiguration Vulnerabilities

Open permissions

Very easy to leave the door open:

- The hackers will always find it

Increasingly common with cloud storage:

- Statistical chance of finding an open permission

June 2017 -14 million Verizon records exposed:

- Third-party left an Amazon S3 data repository open
- Researcher found the data before anyone else

Many, many other examples:

- Secure your permissions

Unsecured admin accounts:

The linux root account:

- The windows Admin account or superuser account

Can be a misconfiguration:

- Intentionally configuring an easy-to-hack password
- 123456, ninja, football

Disable direct login to the root account:

- Use the su or sudo option

Protect accounts with root or admin access:

- There should not be a lot of these accounts

Insecure protocols:

Some protocols aren't encrypted:

- All traffic sent in the clear
- Telnet, FTP, SMTP, IMAP

Verify with a packet capture:

- View everything sent over the network

Use encrypted versions:

- SSH, SFTP, IMAPS, etc.

Default settings:

Every application and network device has a default login:

- Not all of these are ever changed

Mirai botnet:

- Takes advantage of default configurations
- Takes over the Internet of Things (IoT) devices
- 60+ default configurations
- Cameras, routers, doorbells, garage door openers, etc.

Mirai relaxes as open source software:

- There a lot more where that came from

Open ports and services:

Services will open ports:

- Its important to manage access

Often managed with a firewall:

- Manages traffic flows
- Allow or deny based on port number or application

Firewall rulesets can be complex:

- Its easy to make a mistake

Always test and audit:

- Double and triple check

Mobile device security

Challenging to secure:

- Often needs additional security policies and systems

Relatively small:

- Can be almost invisible

Almost always in motion:

- You never know where it might be

Packed with sensitive data:

- Personal and organizational

Constantly connected to the internet:

- Nothing bad happens on the internet

Jailbreaking/rooting:

Mobile devices are purpose-built systems:

- You dont have access to the operating system

Gaining access:

- Android - rooting
- Apple IOS - jailbreaking

Install custom firmware:

- Replaces the existing OS

Uncontrolled access:

- Circumvent security features
- The MDM (Mobile Device Manager) becomes relatively useless

Sideloaded:

Malicious apps can be a significant concern:

- One trojan horse can create a data breach

Manage installation sources:

- The global or local app store

Sideloaded circumvents security:

- Apps can be installed manually without using an app store
- Again, your MDM becomes useless

Zero-day vulnerabilities

Vulnerabilities:

Many applications have vulnerabilities:

- We've just not found them yet

Someone is working hard to find the next big vulnerabilities:

- The good guys share these with developers

Attackers keep these yet-to-be-discovered holes to themselves:

- They want to use these vulnerabilities for personal gain

Zero-day attacks:

Attackers search for unknown vulnerabilities:

- they create exploits against these vulnerabilities

The vendor has no idea the vulnerability exists:

- They don't have a fix to an unknown

Zero day attacks:

- An attack without a patch or method of mitigation
- A race to exploit the vulnerability or create a patch
- Difficult to defend the unknown

Common Vulnerabilities and Exposers (CVE)

- <http://cve.mitre.org/>

Zero day attacks in the wild:

April 2023 - Chrome zero-day:

- Memory corruption, sandbox escape

May 2023- Microsoft zero-day patch:

- secure boot zero-day vulnerability
- Attacker can run UEFI-level self-signed code

May 2023 - Apple iOS and iPadOS zero-days:

- Three zero-day patches
- Sandbox escape, disclosure of sensitive information, arbitrary code execution
- Active exploitations